

Consent Evidence: Product Requirements Document

Feature: Purpose-aware patient consent with compliance evidence and EHR writeback

Target environment: Multi-specialty hospital, staff-assisted patient intake

Primary interfaces: Patient consent experience and hospital compliance console

Author: Yash Bhatt

Version: 1.0

Executive decision

Build one consent service with two deliberately different interfaces. Patients receive a short, plain-language flow showing what they are agreeing to, what is optional, and how to withdraw optional consent. Hospital staff receive a restricted compliance view containing the evidence chain, signature verification, form version, status history, and EHR delivery state.

The product decision is not to expose technical proof such as document hashes, certificate details, internal consent IDs, or integration payloads to patients. Those details support hospital operations and audit defence, but they do not help a patient make an informed choice. The patient receipt translates the record into human terms while authorised staff can inspect the underlying evidence.

No baseline or target completion rate is assumed anywhere in this document. Numbers are set only after the existing workflow is instrumented and a pilot produces observed data.

Context

A modern e-consent platform captures consent digitally, applies legally binding signatures, versions forms, records consent events, and writes signed documents back to hospital EHR systems, with HL7/FHIR connectivity where needed.

The underlying product challenge is larger than digitising a paper form. India's DPDP Act requires consent to be free, specific, informed, unconditional and unambiguous, expressed through clear affirmative action, and limited to the personal data necessary for a specified purpose. It also requires withdrawal to be as easy as giving consent. The DPDP Rules, 2025 add the operational layer: the consent notice must carry a working link through which the patient can withdraw consent, exercise

other rights, and file a complaint with the Data Protection Board — a notice with no functioning withdrawal path does not meet this bar.

ABDM defines a consent artefact as a machine-readable record of the parameters and scope of an approved data-sharing transaction. Consent can be revoked at any time; grants and revocations are recorded on the Health Information Exchange–Consent Manager (HIE-CM) architecture, which notifies the relevant Health Information Providers.

Where a hospital's patient base includes US-linked systems, HIPAA safeguards apply: access controls, audit controls, integrity protections, person or entity authentication, and transmission security. Where 21 CFR Part 11 applies — specifically to electronic records and signatures generated within an FDA-regulated clinical investigation — secure, computer-generated, time-stamped audit trails are a core control. It does not apply to ordinary hospital treatment consent outside that context, and treating it as a blanket requirement overstates its scope.

India's medical record retention rules require physicians to retain indoor and OPD patient records for a minimum of three years from commencement of treatment, longer for medico-legal, pediatric, and obstetric cases. This creates a direct tension with DPDP's erasure-on-withdrawal principle, addressed later in this document.

Product principle: the patient experience should optimise comprehension and control, while the system of record should optimise traceability and evidence.

Problem statement

Hospitals often treat consent as a signed-document problem. A patient is shown a long form containing several purposes, signs once, and the resulting PDF is stored in the EHR. The hospital can prove that a document exists, but may struggle to prove:

- Which version and language the patient saw.
- Which individual purposes the patient accepted or declined.
- Whether optional choices were separated from care-required acknowledgement.
- Who signed and in what capacity.
- What identity check or assisted pathway was used.
- Whether the signed record reached the correct EHR chart.

- Whether a later withdrawal stopped future optional processing.
- Whether an exception was resolved or silently bypassed.

At the same time, exposing this technical evidence directly in the patient flow increases cognitive load without improving the patient's decision. The design therefore needs a patient-facing consent journey and a staff-facing evidence console backed by the same consent record.

Product thesis

A consent is complete only when three conditions are satisfied:

1. **Choice:** The patient received understandable, purpose-specific information and took an affirmative action.
2. **Signature:** The intended signer completed the appropriate signing and identity pathway.
3. **Evidence delivery:** The system created the required evidence record and delivered the signed artefact to the correct patient chart, or surfaced a resolvable exception.

This definition moves the product away from "PDF signed" as the end state. Successful EHR writeback and evidence completeness are part of the product outcome, not an afterthought.

Users and jobs

The personas below are working hypotheses for product design. They should be validated through hospital discovery before implementation.

Patient or authorised representative

An adult patient completing admission or data-use consent on a hospital tablet, sometimes with staff assistance. A representative may sign only when the configured workflow permits it.

Jobs to be done: understand what is required for care and what is optional without reading internal legal or technical language; make separate choices for separate purposes rather than accepting one bundled request; sign using an available and appropriate identity pathway; finish despite language, accessibility, connectivity, or mobile-availability constraints; receive a simple record of choices and know how to change optional consent later.

Failure conditions: accidental opt-in, unclear consequences, forced optional consent, inability to complete without a personal mobile number, or receipt content that reads like an engineering log.

Compliance or health-information officer

A hospital employee responsible for investigating records, supporting audits, resolving consent exceptions, and confirming that the EHR contains the correct document.

Jobs to be done: verify who consented, what they saw, what they selected, and when each event occurred; distinguish patient, guardian, representative, witness, interpreter, and staff roles; confirm document integrity and detect changes after signing; identify EHR writeback failures and resolve them without duplicating the consent; export an evidence package without exposing unrelated patient records; trace withdrawals to downstream processing actions.

Failure conditions: missing form version, mutable event history, unclear signer role, duplicate EHR records, silent sync failures, or excessive access to protected health information.

Front-desk or clinical operations staff

A staff member launches the consent flow from the EHR and assists only when necessary.

Jobs to be done: launch the correct form for the correct patient and encounter; know whether the consent is ready, incomplete, declined, or blocked; use a controlled fallback without bypassing identity or evidence requirements; avoid interpreting clinical or legal text on the patient's behalf.

Failure conditions: wrong-patient launch, untracked assistance, accidental restart, or staff pressure to increase optional opt-in.

Goals and non-goals

Goals

- Make required and optional purposes visibly distinct.
- Capture a defensible evidence chain without showing technical evidence in the patient journey.
- Support signature and identity pathways appropriate to the configured consent type.
- Write the signed artefact and structured status back to the correct EHR chart.
- Surface integration and evidence exceptions to authorised staff.

- Allow optional consent to be reviewed and withdrawn through a similarly accessible path.
- Generate implementation evidence that can be mapped to applicable privacy, security, and electronic-record requirements.

Non-goals

- Providing legal advice or automatically declaring that a hospital is compliant.
- Replacing India's ABDM consent-manager infrastructure for ABDM-governed health-data exchange.
- Maximising optional consent opt-in.
- Showing hashes, certificates, internal record identifiers, network metadata, or EHR payload details to patients.
- Supporting every clinical consent type in the first pilot.
- Delivering offline signing, biometric identity, guardian workflows, and interpreter attestation in the same first release, unless discovery makes one of them a launch blocker.

Experience split

Topic	Patient experience	Compliance console
Identity	"Confirm it's you" with a clear fallback path	Verification method, result, timestamp, attempts, and approved override reason
Purpose	Plain-language cards showing required and optional choices	Purpose code, notice version, lawful configuration, status, and history
Signature	Review statement, signature action, and confirmation	Signature method, signer role, time, artefact integrity state, and verification result
Receipt	Human-readable list of choices, hospital contact, and "manage optional consent" action	Consent record ID, document version, event timeline, delivery attempts, and evidence export
Security	Reassuring copy only where it changes patient behaviour	Role-based access, access log, immutable events, integrity check, and restricted export
EHR status	"Saved to your hospital record" or "Hospital staff will finish saving this"	Patient/encounter match, destination, response status, retry history, and reconciliation action

Proposed flow

Patient flow

1. **Welcome and context:** hospital, care encounter, estimated completion time, language selection, and accessibility controls. No internal record IDs shown.
2. **Purpose-based choices:** care-required acknowledgement separated from optional data uses. Each purpose states what data is involved, why it is needed, who receives it, and how long the choice applies where relevant.
3. **Review:** a short summary of accepted and declined purposes. Optional items remain editable and default to unselected unless the hospital's validated configuration requires otherwise.
4. **Identity and signer role:** confirm whether the person is the patient or an authorised representative, using the configured identity route with controlled staff-assisted fallback where approved.
5. **Sign:** the declaration is presented immediately above the signature action. Signature intent is captured without showing a cryptographic certificate or hash.
6. **Confirmation and receipt:** what was agreed, what was declined, how to get a copy, and how to manage optional consent. The patient sees a plain-language status, not the internal evidence record.

Compliance flow

1. **Consent work queue:** filter by incomplete evidence, EHR delivery failure, withdrawal pending, signer-role exception, form version, and age of exception.
2. **Consent detail:** patient and encounter context, purpose-level choices, signer role, verification outcome, signed document, and current consent state.
3. **Evidence timeline:** append-only events for notice shown, choices changed, identity completed, signature applied, artefact sealed, EHR delivery attempted, delivery confirmed, access, export, and withdrawal.
4. **Integrity panel:** the technical integrity result and the version against which it was calculated. Restricted to authorised roles.
5. **EHR delivery panel:** destination, correlation identifier, attempts, response, and safe retry. A retry must be idempotent and must not create a second active consent record.
6. **Evidence export:** a scoped package containing the signed artefact, purpose-level state, event history, form version, signer information, and delivery evidence.

Success measures

North-star metric — Audit-ready consent completion rate

Eligible consent sessions with a valid signature, complete required evidence, and confirmed EHR writeback ÷ all eligible consent sessions initiated.

"Eligible" excludes test/QA records, cancelled encounters (encounter status change before the session reaches READY_TO_SIGN), and sessions for consent types the hospital's configuration marks as not legally or operationally required for that encounter type. It includes sessions abandoned by the patient — abandonment is a real failure, not a reason to exclude — and sessions currently in DELIVERY_EXCEPTION, which count as incomplete until resolved. A product analyst and compliance owner should confirm this rule before instrumentation ships.

No baseline or target is assigned here; the current value must be measured from production or pilot data.

Driver metrics

Driver	Definition	Why it matters
Informed-choice completion	Sessions reaching a valid purpose-level decision ÷ eligible sessions started	Detects comprehension or flow failure before signature
Signature completion	Valid signatures ÷ sessions reaching signature	Isolates signing and identity friction
First-pass EHR writeback	Records confirmed by the EHR on the first attempt ÷ signed records	Exposes integration reliability
Evidence completeness	Signed records containing every configured required evidence field ÷ signed records	Detects structurally weak records
Exception resolution time	Median time from exception creation to resolved state	Measures operational burden
Withdrawal execution time	Time from valid withdrawal request to downstream status confirmation	Tests whether control exists beyond the user interface

Guardrails

- Median and 90th-percentile patient completion time.
- Staff-assisted completion rate.

- Abandonment by language, device, site, age band, and identity pathway where lawful and appropriate.
- Wrong-patient or wrong-encounter attachment incidents.
- Duplicate active consent records.
- Optional consent acceptance rate monitored for coercion or dark-pattern signals, not treated as a growth KPI.
- Evidence-console access and export anomalies.

Measurement plan

1. Instrument the existing flow for at least two weeks, or until volume is sufficient to establish stable operational patterns.
2. Record the full funnel from EHR launch to confirmed writeback, with an immutable correlation identifier across services.
3. Run a limited pilot at one site and one consent type before broad rollout.
4. Review quantitative outcomes together with support tickets, observed sessions, and staff interviews.
5. Set launch targets only after the baseline and pilot confidence interval are understood.

Functional requirements

ID	Requirement	Actor	Priority
FR-01	Launch the configured consent from an EHR patient and encounter context. Confirm patient identity before the consent starts.	Staff	P0
FR-02	Render the approved notice version in the patient's selected supported language and record the exact version displayed.	Patient, compliance	P0
FR-03	Represent each consent purpose independently with required/optional status, data category, recipient or user, duration where relevant, and current choice.	Patient	P0
FR-04	Require clear affirmative action for optional consent. Optional purposes must not be preselected.	Patient	P0
FR-05	Show a final review containing accepted and declined purposes before signing.	Patient	P0

FR-06	Capture signer role and execute the configured identity and signature policy. Unsupported representative roles must be blocked rather than silently treated as the patient.	Patient, staff	P0
FR-07	Create a versioned signed artefact and append-only evidence events recording actor, action, timestamp, object, result, and correlation identifier.	System, compliance	P0
FR-08	Write the artefact and structured consent status to the correct EHR chart, record the response, and expose failure as an exception.	System, staff	P0
FR-09	Retry EHR delivery idempotently, capped at three automated attempts with exponential backoff. A fourth failure auto-escalates to the staff exception queue, ranked by encounter risk and exception age.	System	P0
FR-10	Show the patient a plain-language receipt without hashes, certificate internals, integration payloads, or internal identifiers.	Patient	P0
FR-11	Provide authorised staff a searchable consent record, evidence timeline, integrity result, and delivery status.	Compliance	P0
FR-12	Allow patients to withdraw optional consent through a route comparable in effort to giving it. Withdrawal creates downstream tasks or API events to stop future processing and, absent another legal basis, triggers the erasure workflow required under DPDP.	Patient, compliance	P0
FR-13	Apply role-based access to consent detail and exports; record all views and exports containing protected information.	Compliance, security	P0
FR-14	Pin the notice/template version at session start. If a new version is published mid-flight, in-progress sessions complete against the version they started with; only new sessions receive the new version.	System	P0
FR-15	Trigger re-consent for a new encounter rather than reusing a prior signed consent, unless the hospital's configured policy explicitly permits reuse for a defined encounter class (for example, recurring dialysis visits under one active consent).	System	P0
FR-16	Support a controlled assisted pathway that records the assisting staff member, reason, and identity route without allowing staff to choose optional consent for the patient.	Staff, patient	P1
FR-17	Provide guardian, nominee, interpreter, witness, and emergency pathways through separately configured policies.	Patient, staff	P1, after workflow validation
FR-18	Support offline capture with delayed synchronisation and conflict handling.	Patient, staff	P2

Retention conflict: withdrawal versus record-keeping duty

This is the sharpest tension in the feature, and it needs an explicit resolution rather than a general "per hospital policy" note.

Situation	Rule that applies	Product behaviour
Patient withdraws optional data-sharing consent (for example, TPA sharing)	Consent-withdrawal rules require processing to stop and data to be erased where no other legal basis exists	Downstream processors (insurer, marketing system) stop use and delete their copy; the consent record itself is retained as evidence of the withdrawal event
Patient asks to delete their entire treatment record	Medical record-keeping regulations override — physicians must retain indoor records for a minimum period, longer for medico-legal, pediatric, and obstetric cases	The deletion request is declined for the clinical record with a plain explanation citing the retention requirement; only consent-adjacent optional data outside the clinical record is deletable
The signed consent artefact itself (not the underlying health data)	Evidence retention tracks the same or a compliance-defined minimum	The signed artefact and event history are never deleted on withdrawal — withdrawal is a new event appended to the chain, not an erasure of the chain

Product rule: **withdrawal changes future processing, never past evidence.** The record documenting "patient signed X, then withdrew Y on this date" must survive regardless of what happens to the underlying data, because that record is the audit defence.

Acceptance criteria

AC-01 Purpose separation — Given a consent template contains one care-required acknowledgement and two optional data-use purposes, when the patient opens the choice screen, then each purpose is displayed separately with its status and explanatory copy, both optional choices are unselected, and refusing either optional purpose does not block the next step.

AC-02 Notice evidence — Given the patient changes the language before making a choice, when the patient continues, then the system records the notice version shown and the version used at signature; it must not record the wrong language as the signed notice.

AC-03 Review and signature intent — Given the patient has made purpose-level choices, when the patient reaches the signature step, then accepted and declined purposes are shown directly before

the declaration and signature action, and any edit returns the patient to an updated review state before signing.

AC-04 Identity failure — Given the configured identity check fails or times out, when the patient requests help, then the system offers only hospital-approved fallback routes, records the selected route and outcome, and prevents staff from marking the identity check successful without the required evidence.

AC-05 Signer role — Given a person selects "I am signing for the patient," when the configured consent type does not permit representative signing, then the system blocks signature, explains that staff assistance is required, and creates no active consent record.

AC-06 Artefact integrity — Given a consent is signed successfully, when the signed artefact is generated, then the system binds it to the notice version, purpose-level choices, signer role, identity result, and signing time; any later alteration must fail the integrity check and create a security event rather than silently replacing the artefact.

AC-07 EHR writeback — Given the signed artefact is valid, when the EHR accepts the writeback, then the consent record moves to COMPLETE, stores the EHR acknowledgement and destination, and shows the patient a simple confirmation that the record was saved.

AC-08 Writeback exception — Given the EHR is unavailable or rejects the request, when writeback fails, then the consent record moves to SIGNED_PENDING_EHR, appears in the staff exception queue, retains the signed evidence, and does not tell the patient that EHR filing succeeded.

AC-09 Idempotent retry — Given a SIGNED_PENDING_EHR record already has a correlation identifier, when an authorised user or automated job retries delivery, then the same signed artefact is sent with the same idempotency key and the system creates no second active consent if the earlier request was accepted but its acknowledgement was lost.

AC-10 Patient receipt — Given consent reaches COMPLETE or SIGNED_PENDING_EHR, when the receipt is displayed, then it shows the patient's accepted and declined purposes, a copy option, hospital contact, and a manage-consent route, while excluding hashes, certificate internals, internal IDs, staff-only comments, and API status codes.

AC-11 Withdrawal — Given an active optional purpose can be withdrawn, when the patient confirms withdrawal, then the purpose state becomes WITHDRAWAL_REQUESTED, a time-stamped event is created, configured downstream processors receive the appropriate instruction, and the state changes to WITHDRAWN only after required confirmation or authorised reconciliation.

AC-12 Restricted compliance access — Given a staff user lacks the configured compliance or records role, when that user attempts to open integrity details or export evidence, then access is denied, the attempt is recorded, and no protected content appears in the response or interface.

State model

State	Meaning	Permitted next states
DRAFT	Session created but no final choice	IN_REVIEW, CANCELLED, EXPIRED
IN_REVIEW	Notice displayed and choices in progress	READY_TO_SIGN, CANCELLED, EXPIRED
READY_TO_SIGN	Required review and identity conditions met	SIGNED_PENDING_EHR, CANCELLED, EXPIRED
SIGNED_PENDING_EHR	Signature valid; EHR confirmation outstanding	COMPLETE, DELIVERY_EXCEPTION
DELIVERY_EXCEPTION	Delivery requires automated or staff resolution	SIGNED_PENDING_EHR, COMPLETE, VOIDED
COMPLETE	Evidence complete and EHR writeback confirmed	WITHDRAWAL_REQUESTED, SUPERSEDED, VOIDED
WITHDRAWAL_REQUESTED	Withdrawal recorded; downstream action pending	WITHDRAWN, WITHDRAWAL_EXCEPTION
WITHDRAWN	Future optional processing stopped as configured	SUPERSEDED
SUPERSEDED	Replaced by a newer valid consent	None
VOIDED	Invalidated through authorised correction	None

A signed record is never edited in place. Corrections create a new version or an authorised void event while preserving the earlier evidence.

Evidence model

Each event minimally contains: consent record and correlation identifiers; patient and encounter references using the minimum necessary identifiers; actor type, actor identifier, and actor role; event

type and result; timestamp from the authoritative service clock; form, notice, language, and policy versions where applicable; purpose identifier and before/after state where applicable; signature and identity method references, without exposing secrets; EHR destination, attempt number, and acknowledgement reference; integrity value and algorithm version in restricted technical metadata.

The evidence model is append-only for regulated events. Operational notes may be amended only through a visible correction event, not overwritten without history.

Security and privacy requirements

- Data is encrypted at rest and in transit, with periodic independent security audits and a full audit trail for consent and signature events.
- Staff access uses role-based permissions and the organisation's configured authentication controls.
- Patient sessions expose only the minimum data needed to confirm context.
- Protected data must not appear in URLs, analytics properties, or client-side error messages.
- Session timeout returns the flow to a safe re-verification state.
- Exports require explicit authorisation and create an access event.
- Integrity metadata is staff-only and must never be treated as patient-facing reassurance copy.
- Logs separate technical diagnostics from the auditable consent-event record while maintaining correlation.
- Data retention and deletion follow the hospital's configured policy and applicable legal obligations; withdrawal does not automatically imply deletion where retention is legally required.

Traceability matrix

Source concern	Product response	Related requirements
Consent must be free, specific, informed, unambiguous, affirmative, and purpose-limited	Separate purposes, optional choices off by default, versioned notice, final review	FR-02 to FR-05; AC-01 to AC-03

Withdrawal should be comparable in ease to giving consent	Patient manage-consent route and tracked downstream execution	FR-12; AC-11
Consent artefacts must specify parameters and scope, and support revocation	Structured purpose record, duration/configuration metadata, status history, revocation workflow	FR-03, FR-07, FR-12
Security controls must address access, audit, integrity, authentication, and transmission security	RBAC, access logging, integrity validation, signer/actor verification, transport controls	FR-06, FR-07, FR-13; AC-04, AC-06, AC-12
Secure, computer-generated, time-stamped audit trails are required where applicable	Append-only, attributed, time-stamped event history and preserved versions	FR-07, FR-11; AC-06
EHR launch and writeback with structured, retrievable delivery	EHR-context launch, structured writeback, acknowledgement, idempotent retry	FR-01, FR-08, FR-09; AC-07 to AC-09

Prioritisation decisions

What enters the first pilot

- Adult patient, self-signing pathway.
- One hospital site and one high-volume, lower-clinical-risk consent type.
- English plus one locally relevant supported language.
- Purpose separation and final review.
- One configured identity/signature route plus one approved assisted fallback.
- Versioned artefact and append-only evidence chain.
- EHR launch, writeback, retry, and exception queue.
- Plain-language patient receipt.
- Staff consent detail, delivery status, and evidence timeline.
- Optional-consent withdrawal if optional data use is included in the pilot.

What is deferred

- Broad procedure-specific consent library.

- Minors, guardians, nominees, interpreters, witnesses, and emergency overrides until clinical and legal workflows are validated.
- Offline-first signing and conflict resolution.
- Biometric authentication.
- Cross-hospital consent portability.
- Automated claims that a record is legally valid across every jurisdiction.

Deferral does not mean these workflows are unimportant. It prevents a first pilot from combining identity, clinical authority, offline synchronisation, EHR integration, and multiple regulatory regimes into one untestable release.

Key trade-offs

Comprehension versus evidentiary detail — Patient copy stays short; technical proof lives in the compliance console. Cost: patients cannot independently inspect implementation-level evidence from the confirmation screen. Mitigation: a downloadable human-readable receipt and a clear route to request the full record where policy permits.

Identity confidence versus completion friction — Use the identity level configured for the consent type rather than the strongest available method for every flow. Cost: different consent types may produce different assurance levels. Mitigation: store the exact method and result, make policy visible to compliance staff, and never present all signatures as equivalent.

Granular choice versus intake speed — Purposes are separated, but the first pilot uses a small, approved purpose set. Cost: the hospital cannot immediately migrate every bundled paper form. Mitigation: measure completion time and observed comprehension before expanding the template library.

Immediate confirmation versus EHR reliability — SIGNED_PENDING_EHR is distinct from COMPLETE. Cost: operations must manage an exception queue. Mitigation: bounded, automated, idempotent retries, ranked by age and encounter risk.

Patient autonomy versus assisted intake — Assistance is permitted, but staff cannot select optional purposes for the patient. Cost: some sessions take longer and may need escalation. Mitigation: record assistance, provide accessible language, monitor assisted completion separately.

Broad coverage versus credible pilot — Start with adult self-signing at one site. Cost: guardian, interpreter, minor, emergency, and offline workflows remain unsolved at launch. Mitigation: treat each as a separately researched workflow with explicit entry criteria.

Dependencies

- Hospital-approved consent template, purpose taxonomy, and translation.
- Legal and compliance review of required versus optional purposes.
- EHR patient/encounter context and document-writeback capability.
- Platform identity, e-signature, audit, encryption, and access-control services.
- Authoritative time service and key-management controls.
- Patient-support and staff-escalation process.
- Downstream processor inventory for optional-consent withdrawal.
- Product analytics schema that excludes protected content.

Risks and mitigations

Risk	Consequence	Mitigation
Required care acknowledgement is presented as optional data consent	Patient confusion and invalid product behaviour	Separate legal/product configurations and have compliance approve each purpose type
Optional choice becomes a conversion target	Dark patterns or staff coercion	Treat optional acceptance as a guardrail, not a success KPI
Wrong EHR context launches the form	Record attached to wrong chart	Patient-context confirmation, correlation ID, and reconciliation workflow
EHR acknowledgement is lost after successful writeback	Duplicate records on retry	Idempotency key and destination-side reconciliation
Technical metadata leaks into patient UI	Confusion and unnecessary exposure	Separate response models and permission-tested UI contracts
Staff uses assisted flow as a shortcut	Weak identity evidence	Reason codes, access controls, monitoring, and sampling for review

Withdrawal updates the consent record but not downstream use	False sense of control	Track downstream acknowledgements and retain an exception state
Deletion request conflicts with medical record retention duty	Legal exposure either way if mishandled	Explicit retention-conflict rule; deletion declined for the clinical record with a cited legal basis where retention wins

Discovery plan

Before final design, conduct targeted interviews and workflow observation with two front-desk or admissions staff, one health-information management or medical-records owner, one privacy or compliance officer, one EHR integration engineer, and four to six patients across language and digital-comfort levels, subject to ethical and institutional approval.

Use real workflow prompts rather than asking whether users "like" the concept. Observe where staff currently identify the patient, how they handle refusal, what happens when the EHR is unavailable, how a guardian is validated, and how an audit request is answered. Replace the working personas and assumptions with observed evidence after synthesis.

Rollout plan

Phase 0: Baseline and configuration — map the current consent flow and evidence gaps; agree event definitions and exclusion rules; validate the selected consent type and purpose taxonomy; confirm EHR test environment, identity policy, and exception owner.

Phase 1: Internal validation — test patient/staff data separation; run accessibility, language, security, and failure-path reviews; validate wrong-patient prevention, duplicate prevention, and EHR outage behaviour; conduct an evidence-package review with compliance before pilot use.

Phase 2: Controlled pilot — release at one hospital site for a defined consent type and limited staff group; monitor the complete funnel and operational exception queue daily; hold weekly readouts with product, engineering, support, hospital operations, and compliance; keep baseline and pilot results separate.

Phase 3: Scale decision — expand only if evidence completeness, EHR delivery, patient completion, and operational workload meet jointly agreed launch gates. If the patient flow improves but exception workload rises materially, resolve the operational bottleneck before scaling.

Open questions

- Which first consent type has sufficient volume and low enough clinical complexity for the pilot?
- What identity level is required for each selected consent purpose and jurisdiction?
- What evidence must remain accessible to the patient versus available on request?
- What is the hospital's source of truth when the consent platform and the EHR report different states?
- Which downstream systems must acknowledge withdrawal before the record becomes WITHDRAWN?
- What representative, guardian, interpreter, and emergency workflows are mandatory for the initial deployment?
- What retention rules apply to signed artefacts, event records, and voided versions?
- Which staff roles may view integrity metadata or export evidence?